Security Policy

The project's security policy and vulnerability reporting guidelines.

Table of Contents

1. Security Philosophy
2. Supported Versions
3. Reporting Vulnerabilities
4. Security Measures
5. Incident Response
6. Audit Information
7. Compliance

Security Philosophy

At GitDigital Products, security is not an afterthought—it's a fundamental design principle. Our security philosophy encompasses:

- **Defense in Depth** - Multiple layers of security controls
- **Least Privilege** - Minimal permissions required for operations
- **Fail Secure** - Safe defaults and graceful degradation
- **Transparency** - Open-source code for community review

Supported Versions

Version	Supported	Notes
1.0.x	✅ Active Development	Current stable release
0.9.x	⚠️ Security Updates	Legacy, limited support
< 0.9.x	❌ End of Life	Not supported

Reporting Vulnerabilities

Responsible Disclosure

We follow responsible disclosure practices. Please report vulnerabilities responsibly:

1. **Do NOT** create public issues or pull requests
2. **DO** report privately to security@gitdigital.products
3. **DO** allow time for patching before disclosure

Reporting Process

```
1. Initial Report → security@gitdigital.products
2. Acknowledgment → Within 48 hours
3. Investigation → Within 7 days
4. Resolution → Based on severity
5. Public Disclosure → After patch release
```

What to Include

- Description of the vulnerability
- Steps to reproduce
- Potential impact
- Suggested fix (if any)

Security Measures

On-Chain Security

1. Authority Validation

```
// All admin operations verify authority
pub fn assert_is_admin(authority: &Pubkey, registry: &Registry) ->
Result<()> {
    if *authority != registry.authority {
        return Err(ErrorCode::Unauthorized);
    }
    Ok(())
}
```

2. Circuit Breaker

Emergency stop mechanism with multi-sig requirements:

- **Activation** - Requires threshold signatures
- **Automatic Triggers** - Velocity limits, anomaly detection
- **Time-locks** - Delay before full activation

3. Transfer Limits

- **Amount Limits** - Maximum per-transaction
- **Velocity Limits** - Transactions per time window
- **Daily Limits** - Rolling 24-hour caps

Off-Chain Security

1. API Authentication

- Rate limiting on all endpoints
- API key rotation policies
- IP allowlisting option

2. Data Encryption

- TLS 1.3 for all communications
- Encrypted storage for sensitive data
- Key management best practices

3. Access Control

- Role-based access control (RBAC)
- Multi-factor authentication
- Audit logging

SDK Security

1. Input Validation

```
// All inputs validated before processing
function validateWalletAddress(address: string): boolean {
  try {
    new PublicKey(address);
    return true;
  } catch {
    return false;
  }
}
```

2. Error Handling

- No sensitive data in error messages
- Proper error codes for debugging
- Logging without PII

Incident Response

Severity Levels

Level	Response Time	Examples
Critical	24 hours	Funds at risk, data breach
High	48 hours	Privacy violation, DoS
Medium	7 days	Logic bugs, config issues
Low	Next release	UI issues, documentation

Response Process

```
┌──────────────────────────────────────────────────────────┐
│                    Incident Response                     │
├──────────────────────────────────────────────────────────┤
│  1. Detection & Triage                                   │
│       ↓                                                  │
│  2. Containment (immediate)                              │
│       ↓                                                  │
│  3. Investigation                                        │
│       ↓                                                  │
│  4. Remediation & Patching                               │
│       ↓                                                  │
│  5. Post-Incident Review                                 │
│       ↓                                                  │
│  6. Public Disclosure (if needed)                        │
└──────────────────────────────────────────────────────────┘
```

Emergency Contacts

- **Security Issues**: security@gitdigital.products
- **Business Hours**: support@gitdigital.products
- **Emergency Line**: Available for critical issues

Audit Information

Third-Party Audits

The protocol has been audited by:

Auditor	Date	Report
Halborn	January 2026	[Report Link]
Neodyme	February 2026	[Report Link]

Audit Scope

- Smart contract security
- Tokenomics integrity
- Access control mechanisms

- Economic exploit analysis

Bug Bounty Program

We maintain a bug bounty program for critical vulnerabilities:

Severity	Bounty
Critical	10,000– 50,000
High	2,500– 10,000
Medium	500– 2,500
Low	100– 500

Compliance

Regulatory Framework

The SDK is designed to help projects comply with:

- **KYC/AML** - Know Your Customer / Anti-Money Laundering
- **GDPR** - General Data Protection Regulation
- **CCPA** - California Consumer Privacy Act
- **BSA** - Bank Secrecy Act (US)

Data Handling

- **User Data** - Stored off-chain, encrypted
- **KYC Data** - Never stored on-chain
- **Transaction Data** - Public (blockchain nature)
- **Audit Logs** - Immutable, comprehensive

Enterprise Features

For enterprise deployments:

- Custom data retention policies
- Dedicated infrastructure
- SLA guarantees
- Dedicated support channels

Best Practices for Integrators

1. Admin Key Management

- Use hardware wallets for admin keys
- Implement multi-sig for critical operations
- Rotate keys regularly
- Keep backups in secure locations

2. Monitoring

- Set up alerts for unusual activity
- Monitor circuit breaker status
- Review audit logs regularly
- Use the admin dashboard

3. Incident Preparedness

- Test circuit breaker functionality
- Document escalation procedures
- Maintain contact list
- Regular security reviews

Security Updates

Notification Process

1. GitHub Security Advisories
2. Email to registered users
3. Discord announcements
4. Blog posts for major issues

Update Policy

- **Critical** - Immediate patch release
- **High** - Within 7 days
- **Medium** - Within 30 days
- **Low** - Next scheduled release

Contact

For security-related inquiries:

- **Email**: security@gitdigital.products
- **PGP Key**: Available on our website
- **Disclosure Guidelines**: See above

Acknowledgments

We thank the following researchers and contributors:

- [Researcher Name] - Vulnerability discovery
- OpenZeppelin Team - Security tooling
- Solana Foundation - Blockchain security resources

Legal

This security policy is subject to change. Last updated: February 2026.

For legal inquiries: legal@gitdigital.products